

Projectdocumentatie – AquaSense (Waterview)

Slim zwembadmonitorsysteem



Sven Van Leemput
Integratieproject - Toegepaste Informatica
AquaSense

API Documentatie – AquaSense (Waterview)

Deze pagina beschrijft alle HTTP-endpoints die door de Next.js-backend worden aangeboden onder `src/app/api/`. De webapplicatie praat met dezelfde origin (REST). Het IoT-device gebruikt het ingest-endpoint met een device-token.

Basis-URL: vervang `{BASE_URL}` door de publieke URL van de deployment (bijvoorbeeld <https://ip-waterview.vercel.app>) Formaat: requests met een body gebruiken Content-Type: `application/json`

1. Authenticatie

1.1 Device-ingest (/api/measurements)

Mechanisme	Beschrijving
Sleutel	API-key (wv_ + hex), alleen zichtbaar bij aanmaken of rotatie
Transport	HTTPS
Header	Één van: X-Device-Token, X-API-Key, of Authorization: Bearer ...

- De server berekent een SHA-256 hash van de ontvangen sleutel en vergelijkt die met `Device.apiKeyHash`.
- Alleen devices met `isActive: true` krijgen toegang.
- Hiervoor is geen Supabase-sessie nodig.

1.2 Admin-API's (/api/admin/...)

Mechanisme	Beschrijving
Supabase Auth-sessie	Cookie-gebaseerde sessie na login (SSR-client <code>createServerClient</code>).
Rol	Profile.role moet ADMIN zijn.

- In de browser roep je deze endpoints meestal aan terwijl je ingelogd bent.
 - De session cookies worden automatisch meegestuurd.
- Gebruik je een eenvoudige HTTP-client (zoals Postman), dan moet je zelf een geldige Supabase-sessie voorzien.
 - Dit kan door cookies over te nemen
 - Of door eerst een login-flow uit te voeren
- Voor admin-routes (`/api/admin/*`):
 - Gebruikers met rol USER krijgen altijd een 403 Forbidden
 - Gebruikers die niet ingelogd zijn, krijgen een 401 Unauthorized

1.3 Publieke health-check

GET `/api/health` vereist geen authenticatie.

2. Overzicht endpoints

Methode	Pad	Actor	Korte beschrijving
GET	/api/health	Publiek	Database-connectiecheck
POST	/api/measurements	Device (API-key)	Nieuwe meetwaarde ingest
POST	/api/admin/devices	Admin	Device aanmaken + API-key uitgifte
GET	/api/admin/devices/name-available	Admin	Controleren of devicenaam vrij is
PATCH	/api/admin/devices/[id]	Admin	Device hernoemen / actief-flag
DELETE	/api/admin/devices/[id]	Admin	Device verwijderen
POST	/api/admin/devices/[id]/api-key	Admin	API-key roteren
PATCH	/api/admin/devices/[id]/pool-dosing	Admin	Zwembaddosering-instellingen (upsert)
PATCH	/api/admin/thresholds/[id]	Admin	Platformdefault-drempel bijwerken
PATCH	/api/admin/device-thresholds/[id]	Admin	Per-device drempel bijwerken
PATCH	/api/admin/profiles/[id]	Admin	Rol van gebruiker wijzigen

Rollen (User vs Admin):

- ADMIN: alle /api/admin/*-routes.
- USER: geen toegang tot /api/admin/* -> 403 indien wel ingelogd: 401 zonder sessie.
- USER gebruikt voor dashboard/historiek geen aparte JSON-API in deze codebase. Dat verloopt via Next.js Server Components en Prisma. Alleen het device roept POST /api/measurements aan.

3. Gemeenschappelijke foutcodes

HTTP	Betekenis	Typische oorzaak
400	Bad Request	Ongeldige JSON, ontbrekende query-parameter, Zod-validatiefout, ongeldig pad-parameterformaat
401	Unauthorized	Geen of ongeldige sessie (admin); ontbrekende/ongeldige device-key (ingest)
403	Forbidden	Wel ingelogd maar geen adminrol
404	Not Found	Onbekend id (device, threshold, profiel)
409	Conflict	Unieke constraint (devicenaam); drempels min $\geq$ max; laatste admin mag niet gedegradeerd worden
422	Unprocessable Entity	Numerieke drempel buiten toegestaan bereik per sleutel
500	Internal Server Error	Onverwachte server-/databasefout (generieke boodschap naar client)
503	Service Unavailable	Health-check: database niet bereikbaar

Antwoordbody bij fouten is doorgaans: { "error": "Mensleesbare uitleg" }

4. Endpoints in detail

- Alle admin-endpoints vereisen een geldige Supabase-sessie en de rol ADMIN. Als je niet ingelogd bent, krijg je een 401 Unauthorized. Ben je wel ingelogd maar heb je geen adminrechten, dan krijg je een 403 Forbidden. Deze foutcodes gelden standaard en worden daarom niet telkens per endpoint herhaald.
- Wanneer er in de documentatie [id] staat, verwacht de server een Prisma cuid. De enige uitzondering hierop zijn de device-thresholds (zie §4.9).
- Bij succesvolle admin-acties wordt, waar relevant, een log toegevoegd aan SystemLog voor auditdoeleinden. Voor ingest-acties gebruikt het systeem logs met de prefix measurement.ingest.*.
- Om admin-endpoints te gebruiken, moet je de juiste session cookies meesturen. In de browser gebeurt dit automatisch na het inloggen. Werk je met een tool zoals Postman, dan moet je deze cookies zelf toevoegen via de header Cookie: <supabase_session_cookies>.

4.1 GET /api/health

Auth: geen (§1.3). Geen parameters.

Status	Body
200	{"status":"ok","database":"connected"}
503	{"status":"degraded","database":"disconnected"}

4.2 POST /api/measurements

Auth: device API-key (§1.1).

Body - schema measurementIngestSchema:

Veld	Verplicht	Constraint
temperatureCelsius	één van drie	-10 ... 50
ph	één van drie	0 ... 14
chlorinePpm	één van drie	0 ... 20
timestamp	nee	ISO 8601 datetime: weglaten -> servertijd

Minstens één meetwaarde moet aanwezig zijn.

Het systeem bepaalt het doeldevice altijd op basis van de API-key. Extra velden in de JSON, zoals een “deviceld” voor debugging, hebben geen invloed op deze koppeling.

Status	Body / notities
201	{"id":"<cuid>","timestamp":"<ISO8601>"}
401	{"error":"Unauthorized"} (+ log measurement.ingest.unauthorized)
400	Invalid JSON of Validation failed + details (+ log bij validation)
500	Internal server error (+ log measurement.ingest.error)

Voorbeeld

```
curl -sS -X POST "{BASE_URL}/api/measurements" \
  -H "Content-Type: application/json" \
  -H "X-Device-Token: ww_<plain_key>" \
  -d '{"ph":7.25,"temperatureCelsius":24.5}'
```

```
{"id":"clhd92examplemeasurementid01","timestamp":"2026-05-05T14:32:01.234Z"}
```

4.3 POST /api/admin/devices

Body (strict JSON)

Veld	Type	Opmerking
name	string?	trim, max 12, default "Pool Monitor"
seedMeasurements	boolean?	alleen bij exact true: ±168 uur demometingen
initialThresholds	array?	max 32× { "key", "value" } keys moeten bestaan in platform Threshold; geen duplicaten

Na het aanmaken van een device worden automatisch DeviceThreshold-waarden ingesteld op basis van de platformdefaults. Als je zelf waarden opgeeft, overschrijven die de standaard per key.

Status	Response / fout
201	id, name, apiKey (plaintext, eenmalig), message
400	Body / duplicate threshold-key / onbekende key
422	Waarde buiten range voor een threshold-key
409	Naam al gebruikt op dit profiel of inconsistent min/max na merge
500	Failed to create device

4.4 GET /api/admin/devices/name-available

Query: name verplicht na trim, 1–120 tekens.

Status	Body
200	{"available":true} of {"available":false,"error":"You already have a device with this name..."}
400	{"available":false,"error":"<validatie>"}

4.5 PATCH /api/admin/devices/[id]

Pad: id = cuid. Body: minstens één van name (1–120 na trim), isActive (boolean).

Status	Body
200	id, name, isActive; bij geen wijziging ook "message":"No changes"
404	Device niet gevonden
409	Naamconflict
400	Ongeldig id of body

4.6 DELETE /api/admin/devices/[id]

- Pad: cuid. 204 zonder body bij succes. 500: Failed to delete device.

4.7 POST /api/admin/devices/[id]/api-key

- Pad: cuid. Geen body. 200: id, name, nieuwe apiKey, message, vorige key ongeldig. 500: Failed to update device key.

4.8 PATCH /api/admin/devices/[id]/pool-dosing

Pad: cuid van een bestaand device. De service valideert enkel bestaan van het device-id. Eigenaar-profiel wordt niet extra gecontroleerd (bescherming = admin-only route).

Body (poolDosingSettingsBodySchema):

Veld	Regel
volumeLiters	verplicht, >0, ≤10 000 000
chlorineProductKind, phMinusKind, phPlusKind	enum (zie hieronder)
chlorineActivePercentOverride enz.	optioneel null; bij CUSTOM moet het bijbehorende override-percent gezet zijn (0–100, zie Zod)

Enums

- chlorineProductKind: SODIUM_HYPOCHLORITE_14, SODIUM_HYPOCHLORITE_125, CALCIUM_HYPOCHLORITE_65, TRICHLOR_90, DICHLOR_56, LITHIUM_HYPOCHLORITE_35, CUSTOM
- phMinusKind: MURIATIC_31, DRY_ACID_SODIUM_BISULFATE, SULFURIC_38, CUSTOM
- phPlusKind: SODA_ASH, SODIUM_BICARBONATE, CUSTOM

4.9 Drempels bijwerken

- Twee routes delen dezelfde body en waardelogica.
- verschil = welke tabel wordt geüpdatet en het id-formaat.

Routes

Route	Pad-parameter
PATCH /api/admin/thresholds/[id]	id = cuid van platform Threshold
PATCH /api/admin/device-thresholds/[id]	id = cuid of legacy id: lengte 12–36, [a-zA-Z0-9_-]+

Body

- { "value": 7.4 }
- value mag een string zijn die naar een getal parseert (komma als decimaal wordt genormaliseerd).

Bereik na parsing (prefix van threshold key):

Prefix	Interval
temperature_	0 ... 45
ph_	6 ... 9
chlorine_	0 ... 10
overige keys in dit schema	–1000 ... 1000

Paren: na elke wijziging moeten temperature_min/temperature_max, ph_min/ph_max, chlorine_min/chlorine_max strict min < max blijven.

Succes 200

- Platform: { "id", "key", "value" }
- Per device: { "id", "key", "value", "deviceId" }

Fouten

- **400** (id-formaat / body)
- **404** (Threshold not found / Device threshold not found)
- **422** (waarde buiten range)
- **409** (min $\geq$ max).

Voorbeeld (platform)

```
curl -sS -X PATCH "{BASE_URL}/api/admin/thresholds/<thresh_row_cuid>" \
-H "Content-Type: application/json" \
-H "Cookie: <supabase_session>" \
-d '{"value":7.4}'
```

4.10 PATCH /api/admin/profiles/[id]**Pad**

- id = Profile.id (cuid), niet Supabase userId.

Body (strict)

- { "role": "USER" | "ADMIN" }.

Succes 200

- 200: { "id", "role" } - ook als de rol al gelijk was.

Fouten

- 404: profiel onbekend.
- 409: degradatie van de laatste admin -> "Cannot remove the last administrator. Promote another user before demoting this account."

5. Succes- en specifieke foutcodes per route

Endpoint	Succes	Codes die vaak extra voorkomen
GET /api/health	200	503
POST /api/measurements	201	
POST /api/admin/devices	201	422, 409
GET .../devices/name-available	200	
PATCH .../devices/[id]	200	409
DELETE .../devices/[id]	204	
POST .../devices/[id]/api-key	200	
PATCH .../pool-dosing	200	
PATCH .../thresholds/[id]	200	422, 409
PATCH .../device-thresholds/[id]	200	422, 409
PATCH .../profiles/[id]	200	409

6. OpenAPI-specificatie en Swagger UI

Wat	URL
Swagger UI (interactief overzicht)	{BASE_URL}/docs
Specificatie (YAML, aanbevolen voor tooling)	{BASE_URL}/api/openapi
Statische kopie (zelfde inhoud; uit public/)	{BASE_URL}/openapi.yaml